PROBLEM STATEMENT NO. 37 · CYBER SECURITY (BCSE410L)

Detection of Payload-Free Pretexting Emails Through Claim-Routed Verification Against Email Headers and Thread History

The claim-routed verification pipeline

PRESENTED BY

M Naga Sai Dattu

23BCE0757

FACULTY

Dr. Arun Prasath G

VIT SCOPE

THE PROBLEM

An email attack with nothing to scan

Some of the most damaging email attacks carry nothing a security scanner can find: no link to a fake website and no attachment with a virus.

Someone writes as your boss, your finance director or a supplier, tells a believable story and asks you to pay, change bank details or send data.

If you believe the story, you do the damage yourself.

Pretexting: building trust through an invented scenario, with the attacker taking part in the conversation [1].

Business email compromise (BEC): pretexting aimed at money.

Payload-free: no link and no attachment; the whole attack is in the words.

WHAT A SCANNER SEES



No link

nothing for a link checker to test



No attachment

nothing to open and inspect



Only a story and a request

the reader is the one who acts

WHY TODAY'S DEFENCES MISS IT

It looks clean to every check

From: "David Chen - Finance Director" <d.chen.finance@gmail.com>
Reply-To: finance.dept.acme@protonmail.com
Authentication: **spf=pass** **dkim=pass** **dmarc=pass** (all for gmail.com)

Hi Priya, **this is David from Finance**. I need you to **process a wire** transfer before 3 PM today. I'm in meetings all day and can't take calls. Please don't loop in anyone else, just get it done.

A made-up example used throughout. Priya works at acmecorp.com, where the real David is the finance director.

1

Scanners look for the payload

Filters inspect links and attachments. This email has neither.

2

Every authentication check passes

SPF [2], DKIM [3] and DMARC [4] all pass, because the email really was sent from a gmail.com account.

3

The checks prove only the domain

"This came from gmail.com" is true, and says nothing about whether the writer is the finance director.

The attack shows only as a disagreement between what the email claims and what its headers prove.

WHO WE DEFEND AGAINST

Two kinds of attacker



The outside impersonator

Writes from a free mailbox, a lookalike domain or a forged copy of your own domain, often with a misleading display name and Reply-To.

WHAT GIVES IT AWAY

The headers do not support the identity the email claims.

CHECKED BY

The header verifier (N3)



The attacker inside a real account

Has taken over a real mailbox, a supplier's account or an ongoing thread. Mail comes from the real sender's domain, so every header check passes.

WHAT GIVES IT AWAY

The conversation changes: new urgency, new bank details, a new way of sending.

CHECKED BY

The thread verifier (N2)

Out of scope: an attacker who has read the mailbox and copies the real sender's reply identifiers, sending details and calm tone. No rule here can catch that message.

EXISTING WORK

What earlier detectors leave open

Work	What it does	What it leaves open
Ho et al. [5]	Detects phishing sent from hijacked accounts inside an organisation	Focuses on emails with a malicious link; the authors note that attacks without one are likely underestimated
BEC-Guard, Cidon et al. [6]	Judges impersonation from the organisation's header history, then reads the body with names and signatures removed	The statements that say who is writing are never compared with the headers
ChatSpamDetector, Koide et al. [7]	Asks GPT-4 to look for impersonation and header spoofing	Its data exclude emails without a link, and each email costs one model call
Paul et al. [8]	Label warning signs such as the organisation a sender claims	Leave the comparison of the claim with the metadata to a later verification step
Karki et al. [9]; Tooher and Lallie [10]	Find persuasion principles in the email text	Read the body only

Our aim: check each claim of a payload-free email against its own headers and its own thread, and give the reason for every alarm.

PREMISE

Check the email the way a fact-checker would

Automated fact-checking splits the work into finding claims, gathering evidence and giving a verdict with its reason [11]. We apply the same steps to an email.

CLAIM

What the email says about itself

"this is David from Finance", "process a wire"

EVIDENCE

What can confirm or contradict it

its own headers and, for a reply, the earlier messages of its thread

VERDICT

Contradiction, consistent or not checkable

each with the rule and the evidence written out

CLAIM CONDITIONING: THE SAME HEADER MEANS DIFFERENT THINGS UNDER DIFFERENT CLAIMS

A private Gmail user writes to a friend

dmarc=pass for gmail.com

✓ Nothing is claimed, so this is normal.

"This is David from Finance", sent from gmail.com

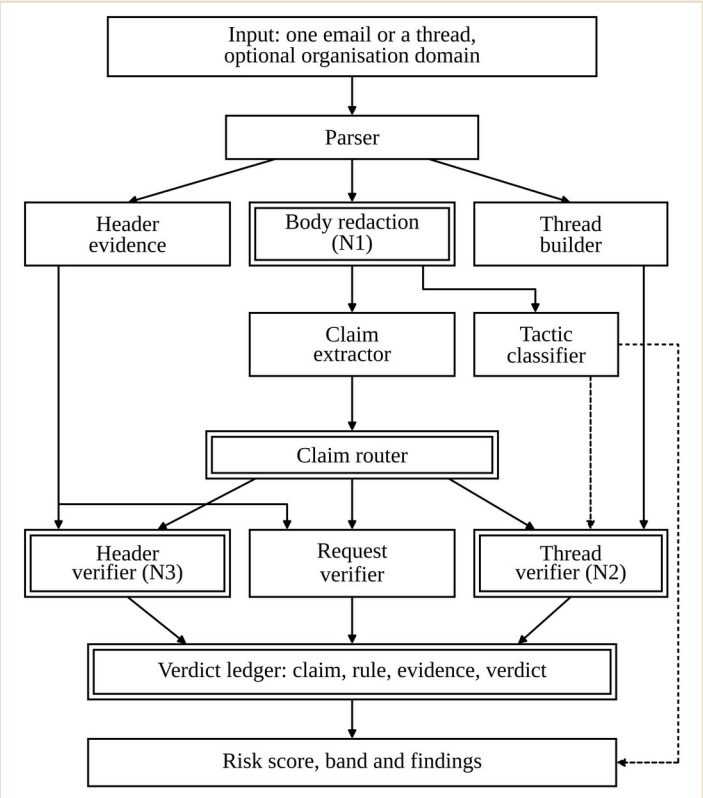
dmarc=pass for gmail.com

✗ Contradiction, high: the claim is internal, the sender is a free mailbox.

Tactics such as urgency only raise the weight of a contradiction; they never create one.

ARCHITECTURE

The claim-routed verification pipeline



1

Split

The parser splits each message into headers, body and thread links. Three branches follow: header evidence, body redaction and the thread builder.

2

Read the body

Links, addresses, domains and file names become placeholders before any model reads the text (N1). A claim extractor finds typed claims; a tactic classifier scores seven tactics, such as urgency and secrecy.

3

Route and check

The router sends each claim to the verifier that can test it: the header verifier (N3), the request verifier or the thread verifier (N2).

4

Record and score

Every verdict is a ledger row naming the claim, the rule and the evidence. The risk score is computed from the ledger.

In the figure, double borders mark the parts introduced in this work; dashed lines carry tactic probabilities to the thread verifier and the score.

ARCHITECTURE

What each verifier asks

Header verifier (N3)

Do the headers support who the email claims to be?

Compares the From domain, the domain that authentication vouched for and the domain the claim implies.

Request verifier

Who is asking for the money or the data?

Flags requests from a free mailbox, a lookalike sender, a failed DMARC check or a Reply-To to another domain.

Thread verifier (N2)

Does this reply fit its own conversation?

Looks for first urgency or secrecy, new bank details, a new sending path and reply links that point to nothing.

THREE POSSIBLE VERDICTS

Contradiction: high, medium or low | **Consistent** | **Not checkable (evidence missing)**

Only contradictions add points: high 60, medium 35, low 5. The strongest finding counts in full; each further claim counts half as much.

Low risk: below 35	Suspicious: 35 to 69	High risk: 70 and above

WORKED EXAMPLE

The fake David, checked claim by claim

Claim found in the body	Checked by	Evidence	Verdict
"this is David from Finance" (internal affiliation)	Header verifier	From gmail.com, a free mailbox; authenticated as gmail.com; organisation acmecorp.com	**Contradiction, high 60 points**
"process a wire" (payment request)	Request verifier	Payment request from a free mailbox outside acmecorp.com	**Contradiction, high +30 points (counts half)**

90

High risk

before any tactic counts

How the score adds up

- Strongest claim, a high contradiction: 60 points.
- Second claim, also high, counts half: 30 points.
- Urgency and secrecy, when detected, raise it further; the score is capped at 100.

Why no row for the Reply-To? It sends answers to protonmail.com, but the body makes no claim about where replies should go, so it appears in the findings and adds no row. The claim decides what a header means.

WORKED EXAMPLE

A hijacked supplier thread

1 Marta, the supplier, sends invoice 4471 with the usual bank account.

2 to 4 An ordinary exchange about delivery and a return fee.

5

From Marta's real address. SPF, DKIM and DMARC pass.

"Our bank has changed this week … Please use our new account for invoice 4471 … Pay today, it is urgent … please do not mention it to anyone at our company and reply only to me."

WHAT THE THREAD VERIFIER SEES

- **Request drift:** a bank account that never appeared in the thread replaces the usual one
- **Tactic onset:** urgency and secrecy appear for the first time
- **Sending-path drift:** a different mail program from Marta's earlier messages
- **Thread integrity: consistent:** the attacker is inside the real account, so the IDs and quotes are real

Message 5 is marked as the point where the thread flipped. With an honest fifth message instead, the result is Low risk.

A made-up demo thread: all names, companies and account numbers are invented.

DATA

Nine public sources and how each is used

99,324

unique emails from nine public sources

20,313

of them attacks

70 / 15 / 15

split by source and category: 69,542 train, 14,879 validation, 14,903 test

Role	Sources
Phishing attacks	Nazario phishing corpus [12]; phishing_pot honeypot samples [13]
Fraud attacks	Nigerian Fraud file of a merged public corpus [14]
Legitimate mail and spam	CEAS-08, Enron [15] and Ling files of the merged corpus [14]; SpamAssassin public corpus [16]
Modern legitimate mail with authentication headers	Apache Kafka and Tomcat user mailing lists [17]

ALSO BUILT

- 1,591 real threads rebuilt from Enron and the Apache lists, for the thread tests
- 690 emails labelled for tactics and claims by two language models of one family, 140 of them in the test split
- Synthetic emails and pairs (an attack and a benign twin), always reported apart from real mail

No source holds both attacks and legitimate mail, so a pooled score mixes corpus and detection. Results are therefore also given per source.

EVALUATION

How we tested

THE RULES WE KEPT

- The test split was frozen before it was read: a hash of every frozen file, checked by every script.
- Each script was rehearsed on validation data first, and every test run was logged.
- 95% intervals from 1,000 bootstrap resamples of whole groups; differences between systems are paired.
- When an interval includes 0, no system is called better.
- Pitfalls checked against Arp et al. [18].

LINKS (N1)

DistilBERT [19] trained on raw text (A) and on redacted text (B). How much does each lose when links are hidden?

Measure: F1 on the attack class

THREADS (N2)

Synthetic takeover replies placed in real threads. Thread rules against header and request rules alone.

Measure: cases detected; false alarms

CLAIMS AGAINST HEADERS (N3)

The routed score against four logistic regressions given the same information.

Measure: F1, recall, false alarm rate, AUC

THE PARTS

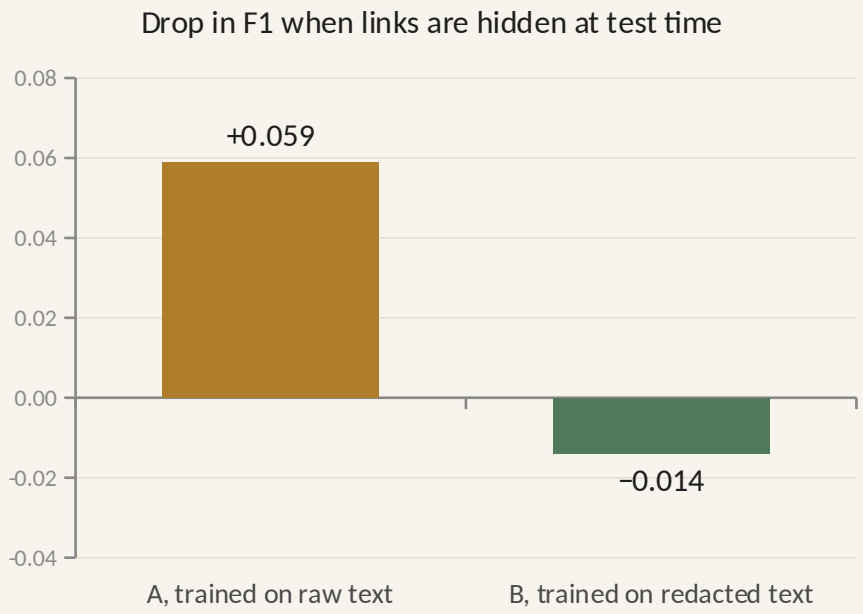
Tactic classifier and claim extractor against LLM labels; the score's false alarm budget.

Measure: macro F1; share of legitimate mail flagged

F1 balances catching attacks against raising false alarms. AUC measures how well a score ranks attacks above legitimate mail, without a cut-off.

RESULT 1 · LINKS (N1)

Part of a normal detector's accuracy comes from reading links



A: +0.059 [+0.050, +0.069]. B: −0.014 [−0.019, −0.009]. F1 on the attack class.

+0.073

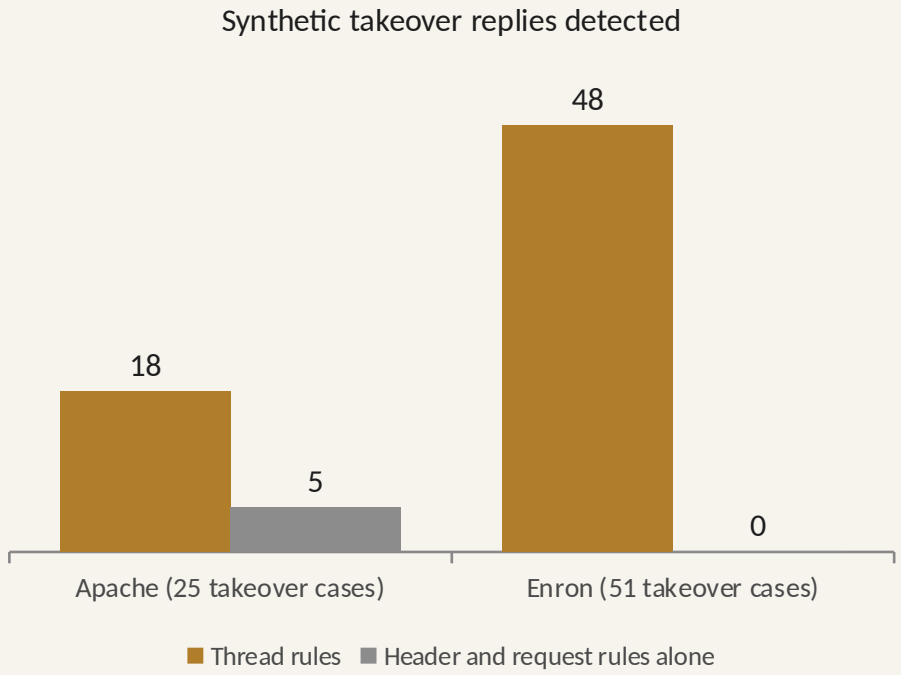
A's drop minus B's drop, 95% interval [+0.061, +0.086]

- The same direction holds for TF-IDF with logistic regression: +0.035 and +0.028.
- Training on redacted text keeps most of the accuracy: B on redacted text scores 0.932, A on raw text 0.935.
- The loss sits in the phishing sources; on Nigerian fraud A's recall stays at 99.4%.

Corpus labels; one training sample of 9,856 emails; two seeds.

RESULT 2 · THREADS (N2)

Thread checks catch takeovers that header checks miss



18 of 25

Apache takeovers found: 72.0%
[52.0%, 88.0%]

48 of 51

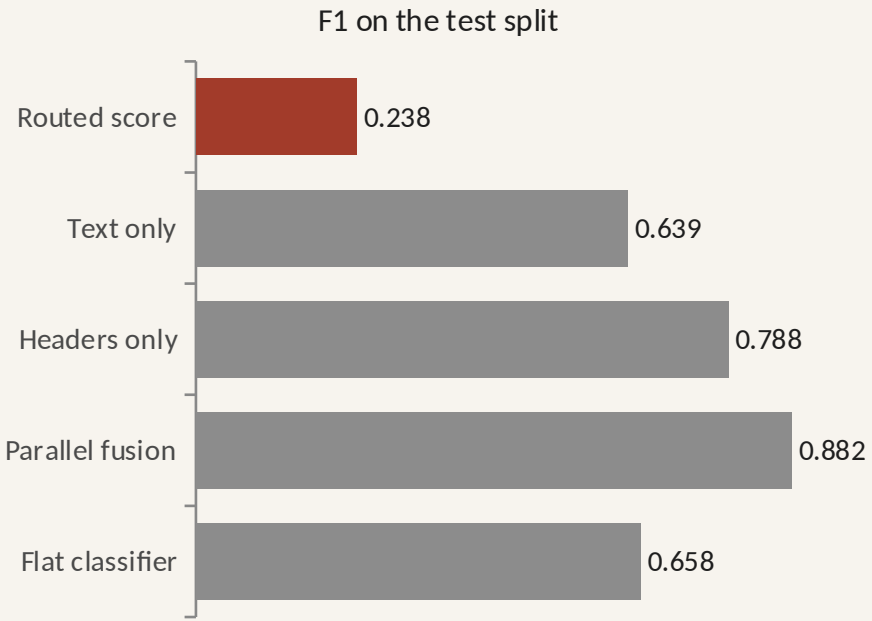
Enron takeovers found: 94.1%
[88.2%, 100.0%]

- Header and request rules alone found 5 of 25 and 0 of 51.
- False alarms on the real next reply: 0 of 25 on Apache, 1 of 51 on Enron.
- Lookalike swaps and forged threads were also caught; these mainly confirm that the rules work as specified.

The injected messages are synthetic, so this tests the rules against the construction, not against real attackers.

RESULT 3 · DETECTION

As a plain detector, the pipeline is not the best



3,045 test attacks against 6,357 legitimate test emails. Learned systems held to the routed score's false alarm rate, with a 0.5% floor.

0.238

routed F1 [0.204, 0.277], recall 13.6%, against 0.882 for parallel fusion

- Its AUC is also the lowest: 0.812, against 0.949 to 0.993.
- It can flag only emails with a checked claim, and 788 of the 3,045 attacks have one. On those, its F1 is 0.679 [0.633, 0.734]: not distinguishable from text only or headers only, still behind fusion.
- The learned systems saw attack labels, and a headers-only model can partly learn which corpus an email came from. Neither removes the gap.

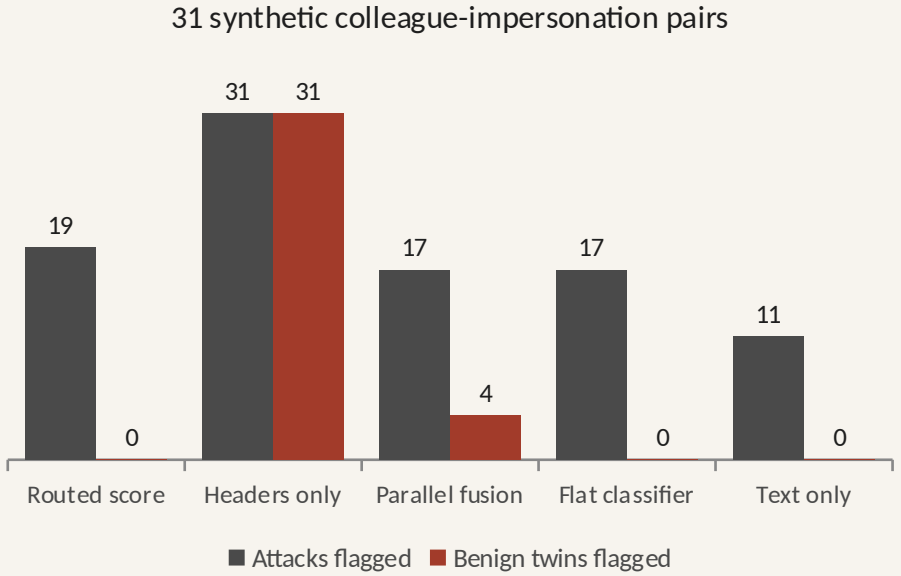
RESULT 4 · EXPLAINED ALARMS

Every alarm comes with its reason

442 of 442

flagged test emails have a claim, a rule and evidence behind them

- None of the flat classifier's 1,819 flags names a claim.
- This is a property of the design, not a measured gain.



Headers only flags every attack and every twin: it cannot tell them apart. The routed score flags 19 attacks (61.3% [45.2%, 77.4%]) and no twins. Text and headers in this arm are synthetic.

RESULT 5 · THE PARTS

Tactics, claims and false alarms

TACTICS

0.479 vs 0.500

Macro F1 of the DistilBERT tactic classifier against a keyword baseline. The difference, −0.021 [−0.144, +0.091], includes 0: neither is better.

CLAIMS

0.568

Macro F1 of the claim extractor over five claim types, with a 95% interval of [0.470, 0.646]. Weakest: internal affiliation, 2 of 12 found.

FALSE ALARM BUDGET

4 of 5

groups of legitimate mail stayed within budget. CEAS-08 ham was over at 5.60% of 268, with an interval [3.42%, 9.03%] that includes the budget.

REWORDING

18 of 24

flags kept after a language model reworded 144 attack bodies. Headers were untouched, so header findings survive by construction.

Tactic and claim scores: 140 labelled test emails, with labels from language models of one family, not people.

IMPLEMENTATION

Built to explain, and to keep nothing



The pipeline

Written in Python. The only trained model used during analysis is the tactic classifier, a DistilBERT model [19] fine-tuned on labelled emails. The claim extractor uses a pretrained name recogniser and 85 hand-written token patterns. No language model runs during analysis.



The web page

Paste an email or a thread and get a risk score from 0 to 100, a band and each finding with its claim, rule, evidence and reason in plain English.



Privacy

No database. Each email is held in memory for one request and then forgotten.

SERVICE PROTECTIONS

- An API key on every request
- A rate limit per client
- A size limit on each email
- A strict schema for every request
- Each report checked against its ledger before it is returned
- Nothing stored after the request

LIMITATIONS

What these results do not show

Never run at a real company. No public set of real payload-free BEC exists.

Tactic and claim labels come from language models of one family, not people (annotator kappa 0.501 and 0.458). Such labels need validation against human labels [20].

No source holds both attacks and ordinary mail, so pooled numbers mix corpus and detection.

Hijack cases and impersonation headers are synthetic: they show that the rules work as defined, not how often real attackers behave that way.

The link test rests on one training sample and two seeds. English only. Internal-affiliation checks need the organisation's domain.

An attacker who copies a real thread's identifiers, sending details and tone is not caught by any rule here.

CONCLUSION

Conclusion and future work

WHAT WE FOUND

- Checking what an email claims against its own headers and thread gives every alarm a stated reason.
- It finds synthetic takeover replies in real threads that header and request rules miss.
- Redacting links is cheap and removes a shortcut.
- On pooled detection over public data sets, it is behind all four learned classifiers.

WHAT WOULD TEST IT ON REAL ATTACKS

- Labelled payload-free BEC emails
- Real hijacked threads that keep the receiving side's authentication headers
- A sample of emails labelled by people for tactics and claims

References

[1] Verizon, “2026 data breach investigations report,” 2026. Accessed: Oct. 12, 2026. [Online]. Available: https://www.verizon.com/business/resources/reports/dbir/

[2] S. Kitterman, “Sender Policy Framework (SPF) for authorizing use of domains in email, version 1,” RFC 7208, Apr. 2014, doi: 10.17487/RFC7208.

[3] D. Crocker, T. Hansen, and M. Kucherawy, Eds., “DomainKeys Identified Mail (DKIM) signatures,” RFC 6376, Sep. 2011, doi: 10.17487/RFC6376.

[4] T. Herr and J. Levine, Eds., “Domain-based message authentication, reporting, and conformance (DMARC),” RFC 9989, May 2026, doi: 10.17487/RFC9989.

[5] G. Ho et al., “Detecting and characterizing lateral phishing at scale,” in *Proc. 28th USENIX Security Symp.*, Santa Clara, CA, USA, 2019, pp. 1273–1290.

[6] A. Cidon, L. Gavish, I. Bleier, N. Korshun, M. Schweighauser, and A. Tsitkin, “High precision detection of business email compromise,” in *Proc. 28th USENIX Security Symp.*, Santa Clara, CA, USA, 2019, pp. 1291–1307.

[7] T. Koide, N. Fukushi, H. Nakano, and D. Chiba, “ChatSpamDetector: Leveraging large language models for effective phishing email detection,” arXiv:2402.18093, 2024.

[8] M. Paul, G. Bartlett, J. Mirkovic, and M. Freedman, “Phishing email detection using inputs from artificial intelligence,” arXiv:2405.12494, 2024.

[9] B. Karki, F. Abri, A. Siami Namin, and K. S. Jones, “Using transformers for identification of persuasion principles in phishing emails,” in *Proc. IEEE Int. Conf. Big Data*, Osaka, Japan, 2022, pp. 2841–2848.

[10] P. Tooher and H. S. Lallie, “A two-stage deep learning framework for AI-driven phishing email detection based on persuasion principles,” *Computers*, vol. 14, no. 12, Art. no. 523, 2025.

[11] Z. Guo, M. Schlichtkrull, and A. Vlachos, “A survey on automated fact-checking,” *Trans. Assoc. Comput. Linguistics*, vol. 10, pp. 178–206, 2022.

[12] J. Nazario, “Phishing corpus.” Accessed: Oct. 12, 2026. [Online]. Available: https://monkey.org/~jose/phishing/

[13] rf-peixoto, “phishing_pot: A collection of real phishing samples collected via honey pots,” GitHub repository. Accessed: Oct. 12, 2026. [Online]. Available: https://github.com/rf-peixoto/phishing_pot

[14] A. Al-Subaiey, M. Al-Thani, N. A. Alam, K. F. Antora, A. Khandakar, and S. M. A. U. Zaman, “Novel interpretable and robust web-based AI platform for phishing email detection,” *Comput. Electr. Eng.*, vol. 120, Art. no. 109625, 2024.

[15] B. Klimt and Y. Yang, “The Enron corpus: A new dataset for email classification research,” in *Machine Learning: ECML 2004*. Berlin, Germany: Springer, 2004, pp. 217–226.

[16] Apache SpamAssassin Project, “SpamAssassin public corpus.” Accessed: Oct. 12, 2026. [Online]. Available: https://spamassassin.apache.org/old/publiccorpus/

[17] Apache Software Foundation, “users@kafka.apache.org and users@tomcat.apache.org mailing-list archives.” Accessed: Oct. 12, 2026. [Online]. Available: https://lists.apache.org/

[18] D. Arp et al., “Dos and don’ts of machine learning in computer security,” in *Proc. 31st USENIX Security Symp.*, Boston, MA, USA, 2022, pp. 3971–3988.

[19] V. Sanh, L. Debut, J. Chaumond, and T. Wolf, “DistilBERT, a distilled version of BERT: Smaller, faster, cheaper and lighter,” arXiv:1910.01108, 2019.

[20] N. Pangakis, S. Wolken, and N. Fasching, “Automated annotation with generative AI requires validation,” arXiv:2306.00176, 2023.